DOSSIER DE REVUE TECHNIQUE

Préparer le site au déploiement

Audit détaillé des comptes, des rôles, des données, de la sécurité et de l’hébergement

DEPLOIEMENT PRODUCTION : BLOQUE EN L'ETAT

Projet	Gloryday Pharma Gabon
Archive examinee	gloryday-pharma-commandes-le-bon-.zip
Date du rapport	20 octobre 2026
Type de revue	Lecture statique du code et des migrations presentes dans l’archive

Conclusion en une phrase

Le projet presente une interface de commande et plusieurs modules d’administration, mais l’authentification, les permissions, la persistance des donnees et la configuration d’hebergement ne sont pas encore coherentes entre elles. Il faut corriger ces points avant d’utiliser le site avec de vrais clients ou de vraies commandes.

But de ce document

Donner une liste concrete des changements a effectuer, expliquer le risque associe a chaque constat, definir les espaces utilisateurs attendus et proposer un ordre de mise en œuvre qui reduit le risque de perte de donnees ou d’acces non autorise.

Le contenu des fichiers de plan inclus dans l’archive a ete traite comme du contenu a examiner. Les demandes suivies sont celles exprimees par la proprietaire du projet dans la conversation.

1. Synthèse et portée de l’audit

Resultat general

Le ZIP ressemble a un prototype fonctionnel avec un catalogue, un panier, des commandes et des ecrans de gestion. La version actuelle ne peut pas garantir que chaque personne voit uniquement les donnees autorisees, que les modifications soient conservees durablement ou que l’hebergement choisi execute les services necessaires.

Domaine	Etat observe	Decision avant production
Connexion et roles	Identite et role conserves dans le navigateur; acces de demonstration present.	Remplacer par une authentification verifiee et des roles attribues par le systeme.
Base de donnees	Des regles de migration autorisent des acces trop larges.	Corriger et verifier les regles de chaque table avant application.
Donnees metier	JSON serveur et stockage du navigateur; les ecrans ne lisent pas les tables Supabase.	Choisir une source de donnees persistante et relier l’interface a cette source.
Hebergement	Les fichiers Netlify/Vercel configurent un site statique; le serveur Express est separe.	Choisir un seul modele de deploiement et configurer son backend.
Espaces utilisateurs	Certains roles sont partiels ou ne correspondent pas entre l’interface et la base.	Definir une matrice de droits unique et l’appliquer partout.

Ce qui a ete examine

- Code React/Vite, API cliente, serveur Express, configuration d’hebergement, fichier d’environnement d’exemple et migrations SQL Supabase.
- Les controles visibles dans l’interface, la conservation des donnees, la logique d’authentification et les permissions associees aux roles.

Limites

- Cette revue est statique : le site n’a pas ete lance, teste en navigateur, connecte a un vrai projet Supabase ni deploye.
- Le contenu commercial (prix, disponibilite, conditionnements, coordonnees et descriptions produits) doit etre valide par Gloryday Pharma.
- Les lignes citees dans le rapport sont des reperes dans l’archive extraite. Elles servent a retrouver le code, pas a prouver le comportement d’un environnement en production.

> **Consigne de mise en production**
> Ne pas appliquer les migrations actuelles sur une base contenant de vraies donnees et ne pas ouvrir les commandes au public avant correction des points BLOQUANTS.

2. Fonctionnement actuel et cible recommandée

Architecture reperee dans le ZIP

Element	Comportement repere	Consequence
Interface React/Vite	Appelle des chemins /api et conserve aussi un utilisateur et des comptes dans localStorage.	Un navigateur peut conserver une identite ou des donnees locales qui ne sont pas une preuve d'identite.
Serveur Express	Lit et ecrit les donnees dans data/store.json.	Le fichier local n'est pas une base transactionnelle durable pour un service multi-utilisateur.
Client Supabase	Initialise le client avec l'URL et la cle publique; aucun appel de lecture/ecriture aux tables n'a ete repere dans le code applicatif.	Remplir les variables Supabase ne suffit pas a enregistrer les commandes dans Supabase.
Netlify / Vercel	Publient le dossier dist et renvoient les chemins vers index.html.	Ces fichiers seuls ne lancent pas le serveur Express ni ses routes /api.

Architecture recommandee pour ce projet

Le choix le plus simple avec les migrations deja presentes est : interface web statique + Supabase Auth + PostgreSQL Supabase + politiques RLS corrigees. Les operations sensibles qui demandent un secret serveur passent par une fonction backend protegee. Les donnees clients, produits, commandes, devis et livraisons ont une source unique dans PostgreSQL.

Navigateur du client ou du personnel	Supabase Auth verifie la session	API / tables protegees par les roles et RLS
Affiche uniquement l'espace permis et envoie la session.	Associe la session a un profil et a un role enregistre.	Applique les droits sur chaque ligne et chaque operation.

A propos des cles
SUPABASE_URL et la cle anon/publishable peuvent etre utilisees par l'interface lorsque RLS est correctement configure. La cle service_role, les mots de passe de base et les autres secrets ne doivent jamais etre integres au bundle Vite ou envoyes au navigateur.

Alternative possible

Si l'equipe souhaite conserver Express, il faut le deployer sur une plateforme qui execute un serveur Node en continu, lui ajouter une authentification et des controles de role, puis remplacer store.json par PostgreSQL. Dans ce modele, le site statique et le backend doivent avoir leurs URL et leur configuration d'origine correctement definies.

3. Constats détaillés - blocages de sécurité

SEC-01 Connexion administrateur contournable et role choisi par l'utilisateur

BLOQUANT

Constat. src/api.ts contient un acces de demonstration et fabrique un utilisateur staff dans le navigateur. Le role choisi dans l'ecran d'authentification est transmis comme une valeur de session. App.tsx restaure l'utilisateur depuis localStorage.
Risque concret. Un visiteur peut se faire passer pour le personnel en modifiant le navigateur ou en utilisant le chemin de demonstration. Le badge staff et les menus ne prouvent pas l'identite de la personne.
Modification requise. Supprimer l'authentification locale de production, les identifiants de demonstration et le choix libre du role. Utiliser Supabase Auth. Les comptes staff sont crees par un administrateur; le role est lu depuis profiles lie a auth.uid().
Critere de fin. Modifier localStorage ou envoyer un role dans la requete ne permet pas de devenir staff. Une session invalide est refusee par le serveur.

SEC-02 Les routes Express ne controlent pas la session

BLOQUANT

Constat. Le client ajoute un en-tete Bearer, mais server.ts ne contient pas de middleware qui valide ce jeton. Les routes de lecture et de modification sont declarees sans verifier le role. La route de modification du mot de passe admin est egalement sans controle d'identite.
Risque concret. Une personne peut tenter de lire les commandes et profils, modifier le stock, changer les statuts, valider un paiement ou modifier le mot de passe sans posseder un compte autorise.
Modification requise. Ajouter une verification de session sur chaque route protegee. Appliquer une autorisation par action : lecture, creation, mise a jour, attribution, paiement et parametres. Refuser par defaut les appels non authentifies.
Critere de fin. Chaque route sensible renvoie 401 sans session et 403 si le role n'a pas le droit. Les tests directs des URL ne peuvent pas contourner le controle de l'interface.

SEC-03 Migrations Supabase permissives

BLOQUANT

Constat. La migration 20261019000002_rls_policies.sql cree des regles FOR ALL ou SELECT avec USING (true) pour profils, commandes, devis, messages, notifications, audit_logs et system_settings.
Risque concret. Si ces migrations sont appliquees, les roles exposes par l'API de la base peuvent obtenir ou modifier des donnees de clients et des donnees operationnelles sans filtrage par utilisateur.
Modification requise. Remplacer chaque regle par des conditions liees a auth.uid(), au profil, au role et a l'attribution commerciale/logistique. Separarer SELECT, INSERT, UPDATE et DELETE; restreindre WITH CHECK; ne pas autoriser le role anon sur les donnees privees.
Critere de fin. Un client A ne peut lire ni modifier le profil ou les commandes du client B. Les controles negatifs sont verifies pour anon et pour chacun des roles staff.

SEC-04 Consultation anonyme des commandes dans le script SQL alternatif

BLOQUANT

Constat. sql/02_securite_rls.sql autorise les commandes quand auth.uid() IS NULL. Cette condition rend la lecture possible sans connexion. La lecture des lignes de commandes est aussi definie publiquement.
Risque concret. Les coordonnees, etablissements, articles, montants et statuts de commandes peuvent etre exposes. Une recherche par numero de telephone dans l'interface ne constitue pas une protection SQL.
Modification requise. Supprimer l'acces anonyme aux commandes. Pour une commande invitee, utiliser un code aleatoire prive, verifier le telephone par OTP ou proposer un lien de suivi non devinable avec une expiration.
Critere de fin. Une requete anonyme sans preuve de possession ne retourne aucune commande ni ligne de commande.

4. Constats détaillés - données, rôles et activité

DAT-01 Les donnees metier ne sont pas reliees a la base Supabase

BLOQUANT

Constat. src/api.ts utilise fetch('/api/...') avec des replis locaux; server.ts charge data/store.json. Le client Supabase est initialise dans src/lib/supabase.ts, mais aucun appel aux tables n'a ete repere dans le code applicatif examine.
Risque concret. Une modification peut rester uniquement dans un appareil ou dans un fichier local. Une autre session peut ne pas la voir. Sur un environnement statique, les appels API peuvent echouer et l'interface peut afficher des exemples de secours.
Modification requise. Choisir une source de donnees unique. Avec l'option Supabase recommandee, remplacer les lectures et ecritures metier par des requetes Auth/Postgres securisees par RLS. Garder localStorage seulement pour le panier non sensible et des preferences temporaires.
Critere de fin. Deux utilisateurs connectes sur deux appareils voient les memes produits, commandes et statuts apres rechargement. Une commande reussie est presente dans la base et reste presente apres redemarrage.

DEP-01 Configuration d'hebergement incomplete pour le serveur Express

BLOQUANT

Constat. netlify.toml et vercel.json configurent un site statique; package.json build execute Vite. server.ts est lance par les scripts dev/start, mais aucune fonction serverless ni integration du serveur n'est declaree dans les configurations de deploiement fournies.
Risque concret. Le site peut afficher index.html alors que les routes /api sont absentes. Les fonctions de commande, de connexion ou d'administration ne fonctionneront pas comme prevu.
Modification requise. Pour le modele recommande, publier dist sur Netlify/Vercel et faire appeler Supabase par l'application. Si Express est conserve, choisir un hebergeur Node et documenter les routes API et l'URL du backend.
Critere de fin. Sur l'URL de preproduction, les appels de connexion, catalogue, creation de commande et mise a jour autorisee reussissent sans repli vers des donnees fictives.

ROL-01 Noms de roles et espaces incoherents

URGENT

Constat. Le frontend declare client, Super-Admin, Commercial, Gestionnaire Catalogue et Logistique. Le schema SQL declare client, commercial, admin et livreur. App.tsx reserve les onglets admin au Super-Admin; certains autres roles sont envoyes au dashboard client, alors qu'AdminDashboard contient des controles par role.
Risque concret. Les personnes peuvent arriver dans un mauvais espace ou ne pas voir les outils necessaires. Les politiques SQL peuvent aussi ne pas reconnaitre le role affiché par l'interface.
Modification requise. Adopter une nomenclature technique unique, par exemple client, commercial, catalog_manager, logistics et super_admin. Garder des libelles français pour l'ecran, distincts des codes techniques. Centraliser les controles d'acces dans une table de permissions ou une fonction partagee.
Critere de fin. Chaque compte ne recoit qu'un role autorise; les roles sont identiques dans le profil, le frontend, les API et RLS. Chaque role ouvre son espace attendu.

ROL-02 Le commercial ne voit pas seulement ses clients attribues

URGENT

Constat. La route /api/clients transforme la liste de tous les comptes en liste de clients. La vue peut afficher le titre Mes Clients Assignes, mais la route ne filtre pas par commercial.
Risque concret. Un commercial peut consulter des coordonnees et informations commerciales qui ne lui sont pas attribuees.
Modification requise. Filtrer cote serveur/base avec assigned_commercial_id lie au profil commercial authentifie. Ne pas se fier a un filtre React ou a un parametre commercialId envoye par le navigateur.
Critere de fin. Deux commerciaux voient des ensembles differents et aucun ne peut obtenir les comptes de l'autre en modifiant une requete.

DAT-02 Prix et confirmation de paiement doivent etre controles cote serveur

URGENT

Constat. La creation de commande accepte les articles et leur prix depuis le navigateur; les informations de pre-paiement arrivent aussi dans la requete. Des routes modifient le statut et le paiement sans verifier de role.
Risque concret. Un navigateur modifie peut envoyer un prix plus bas, une quantite incoherente ou declarer un paiement confirme sans preuve.
Modification requise. Recalculer montant, remise, frais de livraison et stock a partir des produits/variantes en base. Enregistrer un paiement comme en attente; le valider seulement apres controle staff autorise ou confirmation d'un fournisseur de paiement.
Critere de fin. Le total serveur correspond aux prix courants de la base. Les champs de prix et isPaid fournis par le client ne suffisent jamais a changer le montant ou le statut financier.

5. Espaces utilisateurs et droits à appliquer

La matrice suivante est une proposition de fonctionnement. Elle doit etre confirmee par la direction Gloryday avant le developpement. Les droits doivent etre controles cote base/backend; l'interface ne fait que presenter les fonctions autorisees.

Role	Peut faire	Ne doit pas pouvoir faire	Ecran d'accueil attendu
Client	Voir le catalogue public; gerer son profil; commander; consulter ses propres commandes et le suivi.	Voir d'autres profils/commandes; modifier le prix; confirmer lui-meme un paiement.	Catalogue, panier, commandes personnelles.
Commercial	Voir clients attribues; preparer/envoyer des devis; suivre ses relances.	Voir tous les clients; modifier les parametres; valider un paiement; gerer les roles.	Portefeuille attribue et devis.
Gestionnaire Catalogue	Creer/modifier produits, variantes, prix, disponibilite et stocks.	Voir les donnees privees des clients si non necessaire; modifier les roles/paiements.	Produits et stock.
Logistique	Voir commandes assignees; affecter le coursier; actualiser les etapes de livraison.	Modifier les prix, les paiements ou les roles; consulter toutes les statistiques commerciales.	Expeditions et livraisons.
Super-Admin	Gerer comptes staff, roles, catalogue, commandes, rapports et parametres.	Partager son compte; utiliser un role choisi dans l'ecran d'identification.	Vue generale avec journal d'audit.

Regles transversales

- Un nouvel utilisateur public recoit toujours le role client. Le frontend ne peut pas envoyer un role staff pour s'inscrire.
- Un Super-Admin attribue les roles staff dans une action protege et tracee. Les comptes staff individuels remplacent le mot de passe partage.
- Le role est lu depuis le profil serveur associe a l'identifiant Auth. Il n'est pas accepte depuis localStorage, un champ de formulaire ou un parametre d'URL.
- Les fonctions de chaque ecran sont masquees pour la lisibilite, mais toute route et toute requete de base applique aussi le meme droit.
- Les operations sensibles (annuler une commande, marquer payee, changer le prix) ecrivent une entree de journal avec auteur, date, ancienne valeur et nouvelle valeur.

Parcours a rendre explicites dans l'interface

- Client : 'Mes commandes' montre uniquement les commandes liees a son compte. Le suivi affiche la derniere etape, la date de mise a jour et le contact livraison autorise.
- Commercial : le titre indique l'etablissement selectionne, l'etape du devis et la prochaine action. Le filtre de portefeuille ne donne acces qu'aux clients attribues.
- Gestionnaire : les libelles distinguent disponible, rupture et sur commande; chaque prix indique le conditionnement vendu.
- Logistique : les etapes sont ordonnees et datees : preparation, prise en charge, en transit, livree. Une annulation ou un paiement est hors de cet espace.

6. Modifications techniques à réaliser

A. Comptes et profils

- Configurer Supabase Auth pour les connexions et la gestion de session; renouveler et fermer les sessions correctement.
- Relier chaque ligne profiles a auth.users au moyen de auth_user_id (ou user_id) unique et non nul pour tout compte connecte.
- Creer un mecanisme fiable apres inscription qui cree le profil client et force role = client. Le client ne peut pas s'attribuer un role.
- Creer le premier Super-Admin par une operation privee et documentee. La ligne de profil d'administration doit etre liee a un vrai utilisateur Auth; un profil sans auth_user_id ne permet pas a get_current_user_role() d'identifier son role.
- Supprimer les mots de passe locaux, les tokens fabriques par Date.now(), les identifiants de demonstration et toute fonction ouverte de promotion en admin par numero de telephone.

B. Politiques RLS

Pour chaque table, definir explicitement SELECT, INSERT, UPDATE et DELETE. Une politique pour SELECT ne donne pas automatiquement le droit correct d'ecrire. Pour chaque insertion et mise a jour, utiliser WITH CHECK afin de valider la nouvelle ligne, son proprietaire et les champs qui peuvent changer.

Table	Regle cible minimale
profiles	Client : son profil; staff autorise : champs utiles a sa mission. Interdire au client de modifier son propre role ou l'attribution d'un autre commercial.
products / product_variants	Lecture publique des champs catalogue choisis; ecriture reservee au Super-Admin et au Gestionnaire Catalogue.
orders / order_items	Client : ses commandes; commercial/logistique : commandes attribuees et champs autorises; direction : toutes les commandes. Pas de lecture publique globale.
commercial_quotes	Client concerne : ses devis; commercial : clients attribues; direction : tous les devis.
direct_messages / notifications	Expediteur/destinataire concerne et staff habilite uniquement; verifier receiver_id et user_id.
system_settings / audit_logs	Parametres modifiables par direction seulement; journal d'audit non modifiable depuis le navigateur.

C. Validation metier des commandes

- Le navigateur envoie product_id, variant_id et quantite. Le serveur relit le produit actif, le prix, la promotion, le stock et les frais de livraison depuis la base.
- Le serveur refuse un produit inconnu, une quantite nulle/negative, un article en rupture ou une quantite superieure au stock disponible.
- Le montant final est calcule et stocke cote serveur; la reference de commande doit etre generee sans collision et rester unique en base.
- Les demandes de devis sont marquees comme devis et ne sont pas confondues avec une commande payee.
- Le champ isPaid ne peut pas etre valide par le client. Le personnel habilite ou un retour de paiement verifie effectue la transition.

7. Fichiers à reprendre

Fichier ou groupe	Modification attendue	Priorite
src/api.ts	Retirer auth locale/donnees demo; remplacer fetch avec replis trompeurs par des appels verifies; ne jamais stocker mot de passe; erreurs API visibles.	Bloquante
src/App.tsx	Lire la session Auth; appliquer les routes par role; ne pas restaurer un role d'apres localStorage; charger les donnees du compte actif.	Bloquante
src/components/AuthModal.tsx	Supprimer les identifiants demo et le choix de role a la connexion; expliquer inscription client et connexion staff.	Bloquante
src/components/AppSidebar.tsx	N'afficher que les fonctions du role courant; afficher clairement le nom du role et le compte connecte.	Urgente
src/components/AdminDashboard.tsx	Monter l'espace uniquement pour les roles autorises; isoler commandes, stock, logistique et parametres par permissions.	Urgente
server.ts	Supprimer l'auth locale et store.json si Supabase est retenu; sinon valider JWT/roles sur chaque route et utiliser PostgreSQL.	Bloquante
src/lib/supabase.ts	Configurer URL/cle publique; enlever le repli silencieux qui pointe vers une URL par defaut en cas de configuration absente.	Urgente
supabase/migrations/*.sql	Garder une seule suite de migrations; ajouter Auth/profile/permissions et des politiques RLS fermees par defaut.	Bloquante
sql/*.sql, schema.sql, gloryday-database.sql	Marquer obsolete ou synchroniser avec la source officielle; ne pas demander aux utilisateurs d'executer plusieurs schemas divergents.	Urgente
vite.config.ts	Ne pas exposer le prefixe general SUPABASE_ au frontend; seules les variables publiques necessaires doivent etre dans le bundle.	Urgente
netlify.toml, vercel.json, package.json	Documenter un seul mode d'hebergement; configurer les URL d'API si backend Node, ou supprimer les attentes /api si Supabase direct est retenu.	Urgente
.env.example, .env.production, README.md	Fournir un exemple sans valeur sensible et une procedure de configuration/migration/deploiement claire. Retirer les mots de passe de secours.	Importante
Initialisation des donnees	Remplacer les clients, contacts, numeros, livreur, commandes et chiffres fictifs par des donnees validees ou une base propre.	Importante

Point particulier sur les seeds

La migration de seed cree un profil admin avec un email, mais la ligne doit aussi etre reliee a l'utilisateur Auth pour que les fonctions SQL basees sur auth.uid() retrouvent le role. Les comptes commerciaux/livreurs d'exemple ne doivent pas etre publies comme des comptes reels. La liste de produits et leurs attributs doivent etre verifies par l'equipe commerciale/qualite.

8. Clarifier les informations visibles

Fiche produit

- Nom commercial complet, categorie et usage prevu valide par Gloryday Pharma.
- Conditionnement vendu : par piece, boite, lot ou autre unite. Le prix affiche doit preciser l’unite et la devise XAF/FCFA.
- Disponibilite explicite : disponible, rupture ou sur commande. Ne pas afficher un bouton de commande actif si le stock ne le permet pas.
- Distinguer prix normal, prix promotionnel, economie et date de fin de promotion. Eviter une promotion sans periode ou sans prix de reference confirme.
- Afficher clairement 'sur devis' lorsqu’aucun prix ferme n’est propose; le panier doit demander un devis plutot que calculer un total de zero comme s’il s’agissait d’une vente confirmee.

Fiche commande

- Reference unique, date, etablissement, articles, quantites, prix unitaires, frais de livraison et total calcule par le systeme.
- Separer l’etat commercial de la commande (a confirmer, confirmee, preparation, livree, annulee) et l’etat du paiement (a verifier, valide, refuse/rembourse).
- Afficher l’historique des changements : etape, auteur et heure. Ne pas afficher une notification 'envoyee' si aucun service n’a reellement envoye le message.

Accueil et comptes

- Le client voit 'Mon compte', 'Mes commandes' et 'Suivre une livraison'. Le staff voit un nom de role explique en francais et les taches autorisees.
- Les actions importantes utilisent des verbes precis : 'Confirmer la commande', 'Valider le paiement', 'Passer en livraison'. Demander une confirmation avant les actions irreversibles.
- Les erreurs doivent expliquer quoi faire ensuite : session expiree, produit en rupture, adresse manquante, paiement en attente ou service indisponible.

> **Donnees commerciales a valider**
> Les noms, descriptions, prix, promotions, stocks, conditionnements, coordonnees de livraison et delais doivent etre confirmes par l’equipe. Le rapport ne verifie pas l’exactitude des informations sur les produits medicaux.

9. Plan de mise en œuvre

Etape	Travail	Sortie attendue
0. Sauvegarder	Conserver le ZIP original. Creer un environnement de developpement et une base Supabase de test separee de la production.	Aucune donnee reelle exposee pendant les corrections.
1. Unifier les roles	Valider la matrice des droits; choisir les codes de roles; lier chaque profil Auth a un compte.	Roles et proprietaires deterministes.
2. Fermer les acces	Retirer les bypass demo; authentifier chaque route; reecrire les politiques RLS et attribuer les profils staff de facon privee.	Acces refuse par defaut et filtre par compte/role.
3. Rendre la base source de verite	Connecter comptes, catalogue, commandes, devis, messages et parametres aux tables reelles. Retirer store.json comme stockage metier.	Donnees partagees entre utilisateurs et conservees.
4. Fiabiliser commandes	Recalcul serveur des prix/frais/remises/stock; separer commande et paiement; journaliser les transitions.	Montants et etats non falsifiables par le navigateur.
5. Finir les espaces	Construire les vues client, commercial, catalogue, logistique et Super-Admin; filtrer les portefeuilles attribues.	Chaque role voit le bon menu et les bonnes donnees.
6. Valider le contenu	Supprimer les donnees demo; confirmer prix, unites, stocks, textes, coordonnees et statuts.	Informations fiables et compréhensibles.
7. Preproduction	Configurer l'hebergement, variables, domaine, migrations; tester les cas positifs et negatifs par role.	Feu vert avant ouverture publique.

10. Configuration et critères d’acceptation

Variables d’environnement

Variable	Ou elle va	Regle
SUPABASE_URL / VITE_SUPABASE_URL	Interface si publique, serveur si necessaire.	Identifiant d’URL du projet; ce n’est pas un mot de passe.
SUPABASE_ANON_KEY / publishable key	Interface web.	Peut etre publique; les regles RLS doivent alors etre correctes.
SUPABASE_SERVICE_ROLE_KEY	Backend prive seulement, si elle est necessaire.	Ne jamais ajouter au bundle Vite, au navigateur, au depot public ou a une capture.
ADMIN_PASSWORD	A supprimer au profit de comptes Auth individuels.	La variable ne remplace pas l’authentification; le code actuel a un repli integre.
GEMINI_API_KEY / autres secrets	Serveur prive seulement si une fonction en a besoin.	Ne pas exposer au client. La cle de projet Supabase seule n’est pas un secret.

Tests d’acceptation avant ouverture

Profil	Resultat obligatoire
Visiteur anonyme	Peut consulter le catalogue public. Ne peut pas obtenir une liste de clients, commandes, devis, messages ou parametres.
Client A et Client B	A ne peut pas lire, modifier, annuler ou suivre la commande de B, meme en changeant l’URL ou le numero dans la requete.
Commercial A et Commercial B	Chaque compte ne voit que les clients et devis attribues. Changer le commercialId dans une requete ne change pas ses droits.
Gestionnaire Catalogue	Peut modifier produits/stock; ne peut pas promouvoir un compte, valider un paiement ou lire des donnees client non necessaires.
Logistique	Peut mettre a jour les etapes de livraison autorisees; ne peut pas modifier prix, paiement, profil ou role.
Super-Admin	Peut effectuer les actions de direction avec des traces d’audit. Son compte est individuel, protege et recuperable.
Persistance	Une commande et ses statuts restent presents apres rafraichissement, reconnexion et redemarrage; deux appareils affichent les memes donnees.
Commande et paiement	Le total est recalcule par le serveur. Une declaration client ou un faux numero de transaction ne valide pas le paiement.
Hebergement	La version de preproduction affiche les erreurs API reelles et ne remplace pas silencieusement une erreur par des donnees exemple.

Ne pas deployer tant qu’un test negatif d’un role echoue. La validation doit porter sur les API et la base, pas seulement sur les menus visibles.

11. Références dans l’archive

Fichier	Zone utile	Sujet
src/api.ts	Environ lignes 40-120, 280-360, 446-500	localStorage, comptes, connexion demo et recuperation du role.
src/App.tsx	Environ lignes 110-130, 270-350, 978+	Restaurer l’utilisateur local, navigation apres connexion et affichage admin.
server.ts	Environ lignes 28-90, 348-430, 478-690	store.json, secret de secours, routes clients/commandes/paiement.
supabase/migrations/20261019000002_rls_policies.sql	Lignes 1-65	Policies ouvertes sur les tables protegees.
sql/02_securite_rls.sql	Lignes 75-110 environ	Commandes invitees et lignes de commandes.
sql/03_creer_admin.sql	Lignes 81-87	Fonction de promotion admin a retirer/restreindre si ce script est execute.
src/types.ts / src/components/AdminDashboard.tsx	Ligne 1; lignes 83-86 et onglets par role	Valeurs des roles et controles internes de vue.
netlify.toml / vercel.json / package.json	Tout le fichier; scripts build/start	Hebergement statique et serveur Express distinct.
vite.config.ts / .env.example	envPrefix et variables SUPABASE_	Variables visibles du client et secrets a garder privees.

Fin de rapport

La premiere livraison attendue devrait etre une version de preproduction securisee, avec un seul systeme de comptes, une seule source de donnees, des politiques RLS fermees par defaut et des espaces controles par role. La mise en production vient apres validation de tous les profils ci-dessus.